

MARCO INTEGRADO GQM+PRAGMATIC PARA INDICADORES CIBERSEGURIDAD-IA

Trazabilidad Objetivos Nacionales → Métricas Técnicas

Versión: 1.0 | **Fecha:** Enero 2026

Contexto: España | Generative AI Applied to Cybersecurity Risks

Metodología: Goal-Question-Metric (GQM) integrada con PRAGMATIC Criteria

INTRODUCCIÓN: FRAMEWORK INTEGRADO

Este documento articula un marco coherente que traza la línea desde **objetivos estratégicos nacionales españoles** (Plan Nacional de Ciberseguridad, NIS2, EU AI Act) hasta **métricas técnicas específicas de IA-generativa en ciberseguridad**, utilizando metodología GQM como columna vertebral y los 9 criterios PRAGMATIC para validar calidad y ejecutabilidad de cada métrica.

Estructura GQM Jerárquica

NIVEL 1: GOAL (Estratégico)

└ National Cybersecurity Objectives (Plan Nacional, NIS2, EU AI Act)

NIVEL 2: QUESTION (Operacional)

└ Specific capability questions aligned to tactical priorities

NIVEL 3: METRIC (Técnico)

└ Quantifiable measurements with data sources, collection methods

NIVEL 4: PRAGMATIC VALIDATION

└ Quality assessment using 9 PRAGMATIC criteria

SECCIÓN 1: CATEGORIZACIÓN DE OBJETIVOS NACIONALES ESPAÑA

Objetivo Nacional 1: Resiliencia Crítica Infraestructura Digital

Documento Base: Plan Nacional de Ciberseguridad España, NIS2 Directive

Meta Cuantitativa: Reducir tiempo detección incidente crítico de 181 días → <24 horas

Población Objetivo: Essential Entities (utilities, healthcare, critical infrastructure)

Horizonte: 2026-2028

SECCIÓN 2: INDICADORES FRAMEWORK GQM+PRAGMATIC

INDICADOR 1: DETECCIÓN DE AMENAZAS IMPULSADAS POR IA (AI-Threat Detection Coverage)

GQM Structure

GOAL: Lograr capacidad continua detección amenazas generadas-IA en infraestructura crítica, reduciendo MTTD de 181 días a <24 horas

QUESTIONS:

- Q1.1: ¿Qué porcentaje de infraestructura crítica tiene sistemas de detección IA-específicos deployed?
- Q1.2: ¿Cuál es el Mean Time to Detect (MTTD) para ataques impulsados-IA (vs ataques convencionales)?
- Q1.3: ¿Qué tasa de falsos positivos generan sistemas detección IA?
- Q1.4: ¿Cuál es validación accuracy de modelos ML-IDS contra adversarial samples?

METRICS:

Métrica	Definición Operacional	Unidad	Fórmula
M1.1: AI-Detection Coverage %	Porcentaje infraestructura crítica con detección IA-specific	%	$(\text{Assets con ML-IDS} / \text{Total assets críticos}) \times 100$
M1.2: MTTD IA-Threats (días)	Promedio tiempo desde evento al detection	días	$\Sigma(\text{Detection_time} - \text{Event_time}) / n$
M1.3: False Positive Rate	% de alertas que no son amenazas reales	%	$(\text{False_alerts} / \text{Total_alerts}) \times 100$
M1.4: Model Accuracy vs Adversarial	Accuracy modelo ante adversarial attacks	%	$(\text{Correct_predictions} / \text{Total_predictions}) \times 100$

Data Sources:

- SIEM logs (e.g., Splunk, QRadar)
- Endpoint Detection & Response (EDR) platforms
- Threat intelligence feeds
- Red team simulations

PRAGMATIC Validation (9 Criteria)

Criterio	Score (1-5)	Evidencia/Justificación
1. Predictivo	5	MTTD predice breach financial impact; supported by IBM Cost of Breach data (MTTD reduction 20% = -\$1.76M cost)
2. Relevante	5	Directamente alineado Goal ("reducir MTTD"); stakeholders (CISO, CTO) priorizan esta métrica
3. Accionable	4	Scores guían decisión: <24h MTTD → operacional; >7 días → improvement needed. Requiere investment clarity
4. Genuino	5	Basado en real attack telemetry; no es proxy; mide outcome real no activity
5. Significativo	5	Directamente tied to risk reduction; board-level importance; regulatory requirement (NIS2)
6. Preciso	4	Medible objectively; timestamps en sistemas; minor concern: clock synchronization across distributed systems
7. Oportuno	5	Colección continua via SIEM; reporting real-time possible; automated data pipeline viable
8. Independiente	4	No affected by external factors BUT affected by attacker sophistication (threat landscape dependency)
9. Rentable	3	MTTD data costs: SIEM license (€100K annually) + analyst time (€80K annually) = €180K – ROI positivo si breach evitado (avg €500K+ cost) pero initial investment significant
SCORE PRAGMATIC TOTAL	4.3/5	Métrica altamente pragmática; minor burden on infrastructure

INDICADOR 2: MADUREZ GESTIÓN VULNERABILIDADES IA-ESPECÍFICAS (AI Vulnerability Management Maturity)

GQM Structure

GOAL: Implementar sistema risk-based vulnerability management que incorpora amenazas IA-específicas (prompt injection, model extraction, data poisoning) con remediation SLA <15 días críticos

QUESTIONS:

- Q2.1: ¿Cuántos sistemas scanean vulnerabilidades específicas IA (e.g., SBOM validation, model integrity)?
- Q2.2: ¿Cuál es MTTR (Mean Time to Remediate) para vulnerabilidades IA-originated vs tradicionales?
- Q2.3: ¿Qué % de vulnerabilidades IA-related se remedian dentro SLA?
- Q2.4: ¿Existe integración entre threat intelligence y priorización IA-vulnerabilities?

METRICS:

Métrica	Definición	Unidad	Fórmula
M2.1: AI-Vulnerability Scanning Coverage	% sistemas scaneados para vulnerabilidades IA-específicas	%	$(\text{Systems con IA-vuln scanning} / \text{Total deployments}) \times 100$
M2.2: MTTR IA-Vulnerabilities	Promedio días desde identificación a remediation completa	días	$\Sigma(\text{Remediation_date} - \text{Detection_date}) / n_AI_vulns$
M2.3: SLA Compliance IA-Vuln	% remediaciones completadas dentro SLA	%	$(\text{Vulns remediadas on-time} / \text{Total IA-vulns detected}) \times 100$
M2.4: Risk-Based Prioritization Score	Métrica 1-10 incorporando threat intel en priorización	score	$(\text{Criticality} \times \text{Exploitability} \times \text{Threat_actor_interest}) / 10$

Data Sources:

- Vulnerability scanners (Qualys, Rapid7, Tenable)
- SBOM tools
- Threat intelligence platforms
- Ticketing systems (Jira, ServiceNow)

PRAGMATIC Validation

Criterio	Score	Justificación
1. Predictivo	4	MTTR predice incident likelihood but no direct business metric linkage documented
2. Relevante	5	Crítico para compliance NIS2; directamente tied to incident risk
3. Accionable	5	Scores guían: <15 días → goal achieved; >30 días → escalation; >90 días → process failure
4. Genuino	5	Mide real remediation velocity; no es proxy
5. Significativo	5	Board-level importance; tied to regulatory compliance
6. Preciso	4	Medible objectively pero depends on accurate ticket closure dates
7. Oportuno	5	Automated extraction ticketing systems; real-time reportable
8. Independiente	3	Affected by: resource availability, patch vendor timelines, system complexity
9. Rentable	4	Tools + staffing ~ €200K annually; ROI clear if vulnerabilities exploited avoided
SCORE PRAGMATIC TOTAL	4.4/5	Altamente pragmática; established process; minor external dependencies

INDICADOR 3: CAPACIDAD DETECCIÓN DEEPFAKES Y MANIPULACIÓN CONTENIDO (Deepfake Detection Readiness)

GQM Structure

GOAL: Desplegar capacidad real-time multimodal detección deepfakes para proteger comunicaciones críticas, alcanzando 94%+ accuracy con <2 segundos latencia

QUESTIONS:

- Q3.1: ¿Cuántas organizaciones críticas tienen deployed deepfake detection systems?
- Q3.2: ¿Cuál es accuracy detección deepfakes en conditions reales (vs laboratorio)?
- Q3.3: ¿Cuál es latencia de detección (real-time capable para llamadas video)?
- Q3.4: ¿Qué % empleados son educados en deepfake recognition?

METRICS:

Métrica	Definición	Unidad	Fórmula
M3.1: Deepfake Detection Deployment %	% infraestructura crítica con sistemas deployed	%	$(\text{Orgs con deepfake detection} / \text{Total critical orgs}) \times 100$
M3.2: Detection Accuracy Real-World	Accuracy modelo en conditions reales (no lab)	%	$(\text{Correct_classifications} / \text{Total_tested}) \times 100$
M3.3: Detection Latency	Tiempo entre input y detection alert	segundos	$\text{Average_detection_time_ms} / 1000$
M3.4: Deepfake Recognition Training Coverage	% empleados completó entrenamiento deepfake recognition	%	$(\text{Trained_employees} / \text{Total_employees}) \times 100$

Data Sources:

- Deepfake detection platforms (multimodal)
- Security awareness training LMS
- Real incident telemetry

PRAGMATIC Validation

Criterio	Score	Justificación
1. Predictivo	3	Detecta amenazas but no predictive forward element; reactive
2. Relevante	4	Relevante para critical communications pero aplicabilidad limitada (no todas orgs)
3. Accionable	4	Actionable pero requiere change proceso comunicación (pre-verification protocols)
4. Genuino	4	Mide capability real pero training coverage es proxy imperfecta de resistance
5. Significativo	4	Significant para high-value targets pero no universal threat
6. Preciso	3	Accuracy measurement difícil: depends on test dataset quality; lab vs real degradation
7. Oportuno	3	Detection puede ser real-time pero training tracking manual/sparse
8. Independiente	2	Highly dependent on: deepfake generation sophistication, video quality, model training data
9. Rentable	2	High cost: detection systems €500K+; deployment friction; ROI uncertain (prevention vs cure trade-off)
SCORE PRAGMATIC TOTAL	3.1/5	Moderadamente pragmática; significant cost; dependency issues; emerging technology uncertainty

INDICADOR 4: COBERTURA SIEM-THREAT HUNTING CON IA (SIEM + AI-Threat Hunting Maturity)

GQM Structure

GOAL: Implementar continuous AI-augmented threat hunting program detectando ataques complejos 90%+ antes de business impact

QUESTIONS:

- Q4.1: ¿Cuántos eventos/día procesa SIEM con ML correlation?
- Q4.2: ¿Qué % detecciones son automatizadas vs manually triggered?

- Q4.3: ¿Cuál es investigación time-to-close para threat hunts automatizadas?
- Q4.4: ¿Cuántas brechas potenciales se identifican proactivamente vs reactivamente?

METRICS:

Métrica	Definición	Unidad	Fórmula
M4.1: SIEM Event Processing Capacity	Volumen eventos procesados diarios con ML	eventos/día	$\text{Total_events_processed_ML} / \text{day}$
M4.2: Automated Detection %	% detecciones triggeradas por ML vs manual	%	$(\text{ML_detections} / \text{Total_detections}) \times 100$
M4.3: Threat Hunt Investigation Time	Promedio tiempo investigación hasta resolution	horas	$\Sigma(\text{Investigation_close} - \text{Investigation_open}) / n$
M4.4: Proactive vs Reactive Discovery	% amenazas encontradas proactivamente	%	$(\text{Proactive_detections} / \text{Total_detections}) \times 100$

Data Sources:

- SIEM platform metrics
- Threat hunting platform (e.g., Splunk Enterprise Security, Chronicle)
- Incident ticketing

PRAGMATIC Validation

Criterio	Score	Justificación
1. Predictivo	5	Proactive detection predicts breach prevention; measurable ROI
2. Relevante	5	Altamente relevante; stakeholders prioritize threat hunting
3. Accionable	5	Scores guide: <24h investigation time – system working; >7 days – tuning needed
4. Genuino	4	Mide capability real pero dependent on hunt quality (not just volume)
5. Significativo	5	Critical para incident prevention; board-level
6. Preciso	4	Medible objectively; timestamps en sistemas
7. Oportuno	5	Automated SIEM metrics; real-time reporting
8. Independiente	3	Affected by: attacker sophistication, false positive tuning, analyst skill
9. Rentable	4	SIEM + threat hunting tools ~ €400K annually; ROI significant if breaches prevented
SCORE PRAGMATIC TOTAL	4.4/5	Altamente pragmática; established practices; strong ROI

INDICADOR 5: CAPACITACIÓN CONCIENCIA IA-CIBERSEGURIDAD (AI-Cybersecurity Awareness Training Effectiveness)

GQM Structure

GOAL: Lograr 85%+ de empleados resilientes a AI-enhanced phishing (click rate <5%, reporting rate >70%) mediante entrenamiento continuous adaptivo

QUESTIONS:

- Q5.1: ¿Cuál es phishing click-rate para emails AI-generated vs tradicionales?
- Q5.2: ¿Cuál es employee reporting rate para suspicious phishing?
- Q5.3: ¿Cuál es retención conocimiento post-training?
- Q5.4: ¿Cuántas organizaciones implementan IA-specific awareness módulos?

METRICS:

Métrica	Definición	Unidad	Fórmula
M5.1: AI-Phishing Click Rate	% empleados que clickea phishing IA-generated	%	$(\text{Clicks} / \text{Total_recipients}) \times 100$
M5.2: Phishing Reporting Rate	% empleados que reporta phishing en lugar de clickear	%	$(\text{Reported} / \text{Total_phishing_sent}) \times 100$
M5.3: Training Retention Score	Puntuación post-training assessment retenimiento	score (1-10)	$\text{Average_post_training_assessment_score}$
M5.4: AI-Awareness Program Deployment	% organizaciones con AI-specific training	%	$(\text{Orgs con AI-training} / \text{Total_orgs}) \times 100$

Data Sources:

- Phishing simulation platform (Gophish, KnowBe4)
- LMS learning assessments
- Organizational surveys

PRAGMATIC Validation

Criterio	Score	Justificación
1. Predictivo	4	Click-rate predicts phishing susceptibility; supported by research correlation
2. Relevante	5	Crítico para human-factor defense; employee conduct directly impacts risk
3. Accionable	5	Actionable: <5% click – goal; 10-20% – intervention; >30% – failure
4. Genuino	4	Mide behavioral outcome real pero simplified (not capturing sophistication)
5. Significativo	5	Significant: human error causa 25%+ breaches
6. Preciso	5	Objectively medible; automated tracking in phishing platforms
7. Oportuno	5	Continuous simulation data; automated metrics
8. Independiente	2	Highly affected by: email content sophistication, time pressure, attention/fatigue
9. Rentable	4	Phishing simulator + training ~ €80K annually; cost-effective for breach prevention
SCORE PRAGMATIC TOTAL	4.2/5	Altamente pragmática; pero dependent on behavioral factors

INDICADOR 6: COMPLIANCE MADUREZ NIS2/EU AI ACT (Regulatory Compliance Maturity)

GQM Structure

GOAL: Alcanzar 95%+ cumplimiento requisitos NIS2 + EU AI Act en entidades críticas españolas antes agosto 2026

QUESTIONS:

- Q6.1: ¿Qué porcentaje entidades esenciales completó assessment NIS2?
- Q6.2: ¿Cuál es maturity score vs ISO 27001?
- Q6.3: ¿Cuántos Gap Assessments vs EU AI Act requirements ejecutados?
- Q6.4: ¿Cuál es % audit findings resolved within SLA?

METRICS:

Métrica	Definición	Unidad	Fórmula
M6.1: NIS2 Assessment Coverage	% entidades esenciales completó NIS2 self-assessment	%	$(\text{Assessed_entities} / \text{Total_EE}) \times 100$
M6.2: ISO 27001 Alignment Score	Maturity 0-5 vs ISO 27001 control alignment	score (0-5)	$\text{Controls_implemented} / \text{Controls_required}$
M6.3: EU AI Act Gap Analysis Coverage	% organizaciones ejecutó formal gap assessment	%	$(\text{Gap_assessed} / \text{Total_organizations}) \times 100$
M6.4: Audit Finding Resolution Rate	% audit findings resolved within 30 days	%	$(\text{Resolved_30d} / \text{Total_findings}) \times 100$

Data Sources:

- CNCS (Centro Nacional de Ciberseguridad) España official assessments
- Internal audit reports
- Gap assessment documentation
- INCIBE compliance tracking

PRAGMATIC Validation

Criterio	Score	Justificación
1. Predictivo	3	Compliance es lagging indicator; no predicts future breach
2. Relevante	5	Mandated by regulation; stakeholders require
3. Accionable	4	Actionable pero requires remediation planning (not just scoring)
4. Genuino	3	Mide compliance checkbox completion; imperfect proxy for actual security
5. Significativo	5	Significant: regulatory required; board/CNCS mandate
6. Preciso	3	Medible but subject to interpretation de requirements (audit inconsistency)
7. Oportuno	3	Annual reporting cycles; not continuous; lag in data availability
8. Independiente	4	Relatively independent; regulatory standard is fixed
9. Rentable	3	Compliance tracking costs (internal/external audit) ~ €150K annually; overhead without breach prevention ROI
SCORE PRAGMATIC TOTAL	3.7/5	Moderadamente pragmática; compliance-driven pero imperfect security predictor

INDICADOR 7: RESILIENCIA CADENA SUMINISTRO IA (AI Supply Chain Resilience)

GQM Structure

GOAL: Asegurar 100% de componentes IA (modelos, librerías, datos) en cadena suministro tienen provenance tracking y verificación integridad, con zero unauthorized components deployed

QUESTIONS:

- Q7.1: ¿Cuál es cobertura SBOM (Software Bill of Materials) para componentes IA?
- Q7.2: ¿Cuántos proveedores IA completaron security assessment?
- Q7.3: ¿Cuál es % modelos verificados criptográficamente pre-deployment?
- Q7.4: ¿Existe ingesta control automatizada para componentes terceros?

METRICS:

Métrica	Definición	Unidad	Fórmula
M7.1: SBOM AI Component Coverage	% componentes IA con documented SBOM	%	$(\text{Components_documented_SBOM} / \text{Total_AI_components}) \times 100$
M7.2: Vendor Security Assessment Completion	% AI vendors completó security evaluation	%	$(\text{Vendors_assessed} / \text{Total_AI_vendors}) \times 100$
M7.3: Cryptographic Verification Rate	% modelos/datos verificados integridad pre-deploy	%	$(\text{Verified_components} / \text{Total_components}) \times 100$
M7.4: Unauthorized Component Incidents	# componentes maliciosos detected/blocked	count	Total_malicious_components_detected_YTD

Data Sources:

- Package managers (PyPI, npm, Hugging Face)
- Vulnerability management systems
- Vendor assessment documentation
- Deployment logs

PRAGMATIC Validation

Criterio	Score	Justificación
1. Predictivo	5	SBOM + verification predicts supply chain breach prevention
2. Relevante	5	Crítico para emerging threat (2025: supply chain attacks rising)
3. Accionable	4	Actionable pero requiere proceso rigor (vendedor cooperation)
4. Genuino	5	Mide control implementación real
5. Significativo	5	Significant: supply chain breaches have massive impact (precedent: SolarTrade \$500M)
6. Preciso	4	Medible objectively pero depends on vendor compliance
7. Oportuno	3	Requires manual SBOM generation; not all tools support automation
8. Independiente	3	Affected by: vendor security posture, upstream supply chain visibility
9. Rentable	3	SBOM tools €200K+; vendor assessment labor intensive; ROI long-term
SCORE PRAGMATIC TOTAL	4.0/5	Pragmática pero con friction operacional; emerging practice

INDICADOR 8: RESPUESTA A INCIDENTES IA-POWERED (AI-Enhanced Incident Response Capability)

GQM Structure

GOAL: Implementar SOAR + IA para reducir MTTR (Mean Time to Respond) de 4+ horas a <30 minutos, con automatización de 80%+ de respuestas inicial

QUESTIONS:

- Q8.1: ¿Cuál es MTTR promedio para incidentes detectados?
- Q8.2: ¿Qué % respuestas iniciales están automatizadas?
- Q8.3: ¿Cuál es tasa escalation vs auto-resolution?
- Q8.4: ¿Cuántos playbooks de respuesta están documentados?

METRICS:

Métrica	Definición	Unidad	Fórmula
M8.1: MTTR Automatizado	Promedio tiempo respuesta inicial automatizada	minutos	$\Sigma(\text{Response_time}) / n_automated_responses$
M8.2: Automation Rate	% respuestas iniciales ejecutadas sin intervención humana	%	$(\text{Automated_responses} / \text{Total_responses}) \times 100$
M8.3: Auto-Resolution Rate	% incidentes resueltos completamente sin escalation	%	$(\text{Auto_resolved} / \text{Total_incidents}) \times 100$
M8.4: Playbook Coverage	# playbooks documentados / total incident types	count	Playbooks_documented

Data Sources:

- SOAR platform metrics (e.g., Paloalto Cortex, Splunk SOAR)
- Ticketing system time-stamps
- Incident tracking database

PRAGMATIC Validation

Criterio	Score	Justificación
1. Predictivo	5	MTTR reduction directly predicts incident damage reduction
2. Relevante	5	Altamente relevante; central a incident management
3. Accionable	5	Actionable: <30 min → goal; >2 hours → analysis needed
4. Genuino	5	Mide automation capability real
5. Significativo	5	Significant: MTTR impact directly on financial loss
6. Preciso	4	Medible objectively; timestamps en sistemas
7. Oportuno	5	Continuous monitoring; real-time dashboards
8. Independiente	3	Affected by: incident complexity, system dependencies, skill availability
9. Rentable	5	SOAR tools ~€300K annually but ROI massive (prevent hours of analyst time)
SCORE PRAGMATIC TOTAL	4.6/5	Altamente pragmática; strong operational value

INDICADOR 9: LIDERAZGO Y GOBERNANZA CIBERSEGURIDAD IA (AI Security Governance Maturity)

GQM Structure

GOAL: Establecer governance formal con CISO reporting to CEO, presupuesto dedicado IA-security, y risk appetite articulated por board

QUESTIONS:

- Q9.1: ¿Reporta CISO to CEO o subordinate leader?
- Q9.2: ¿Existe presupuesto dedicado IA-security (vs buried in general cybersecurity)?
- Q9.3: ¿Revisa board ciberseguridad IA trimestralmente?
- Q9.4: ¿Existe risk appetite statement formal para IA?

METRICS:

Métrica	Definición	Unidad	Fórmula
M9.1: CISO Reporting Level	Hierarchical level: 0=none, 1=CTO, 2=COO, 3=CEO	score (0-3)	Reporting_hierarchy_level
M9.2: IA-Security Budget %	% presupuesto ciberseguridad dedicado IA-specific	%	$(\text{AI_security_budget} / \text{Total_cyber_budget}) \times 100$
M9.3: Board Review Frequency	# veces/año board revisa ciberseguridad IA	frequency	Board_reviews_per_year
M9.4: Risk Appetite Documentation	0=no documento, 1=existe pero no comunicado, 2=formal + distributed	score (0-2)	Risk_appetite_maturity

Data Sources:

- Organizational charts
- Budget allocation documents
- Board meeting minutes
- Policy documentation

PRAGMATIC Validation

Criterio	Score	Justificación
1. Predictivo	5	Governance structures predict resource allocation y security investment
2. Relevante	5	Crítico para strategic alignment; precondition para other initiatives
3. Accionable	3	Actionable pero requiere executive decision-making; not technical team autonomy
4. Genuino	5	Mide governance real (not proxy)
5. Significativo	5	Foundational: governance predicts success todas otras iniciativas
6. Preciso	4	Medible objectively pero interpretación puede variar (CTO vs COO distinction)
7. Oportuno	2	Annual assessment cycles; not continuous; data collection dependent on manual reporting
8. Independiente	5	Relatively independent; internal organizational choice
9. Rentable	5	No direct cost; organizational design exercise; massive ROI in strategic alignment
SCORE PRAGMATIC TOTAL	4.2/5	Pragmática pero con gaps oportuno; requires organizational change

SECCIÓN 3: MATRIZ CONSOLIDADA GQM+PRAGMATIC

Indicador	Goal Estratégico	# Questions	# Metrics	Avg PRAGMATIC Score	Recomendación
1. AI-Threat Detection	MTTD <24h	4	4	4.3	IMPLEMENTAR INMEDIATAMENTE
2. Vulnerability Management IA	Remediation <15d	4	4	4.4	IMPLEMENTAR INMEDIATAMENTE
3. Deepfake Detection	94%+ accuracy	4	4	3.1	Implementar pero menor urgencia
4. SIEM+Threat Hunting	Proactive detection 90% +	4	4	4.4	IMPLEMENTAR INMEDIATAMENTE
5. Awareness Training	Click-rate <5%	4	4	4.2	IMPLEMENTAR INMEDIATAMENTE
6. Compliance NIS2/AI Act	95%+ compliance	4	4	3.7	Implementar (mandated)
7. Supply Chain Resilience	SBOM 100% coverage	4	4	4.0	Implementar fase 2 (2027)
8. Incident Response IA	MTTR <30 min	4	4	4.6	IMPLEMENTAR INMEDIATAMENTE
9. Governance Maturity	CISO to CEO	4	4	4.2	IMPLEMENTAR INMEDIATAMENTE (foundation)

SECCIÓN 4: RECOMENDACIONES DE IMPLEMENTACIÓN PRIORIZADA

Fase 1: Implementación Inmediata (Q1 2026)

Indicadores: 1, 2, 4, 5, 8, 9

Justificación: Highest PRAGMATIC scores (4.2-4.6); foundational para otras iniciativas

Presupuesto: €1.2M Year 1

Expected Outcome: Reducción MTTD 300x; automation 80%+ respuesta inicial

Fase 2: Implementación Secundaria (Q2-Q3 2026)

Indicadores: 3, 6

Justificación: Compliance-required (NIS2, EU AI Act) pero operational complexity menor

Presupuesto: €500K Year 1

Fase 3: Implementación Avanzada (Q4 2026-Q1 2027)

Indicadores: 7

Justificación: Supply chain resilience emerging; vendor maturity still developing

Presupuesto: €350K Year 1

FIN DEL MARCO GQM+PRAGMATIC